



INDICATORS OF BEHAVIOR



From Indicators to Insight

Operational Validation of Behavior-Based Cyber Detection in a Live Biotechnology SOC

Charles Frick
Chief Scientist, Cyber Capabilities Development Group
Johns Hopkins Applied Physics Laboratory
Charles.Frick@jhuapl.edu

The Problem

- Security operations are flooded with alerts but still miss real attacks
- Indicators of Compromise (IOCs):
 - Static artifacts (IPs, hashes, domains)
 - Easily changed by adversaries
 - Often identified after damage has begun
- Even with STIX and ATT&CK:
 - These standards and frameworks do not provide enough specificity for action
 - But we don't operationalize them well

We collect signals but struggle to connect them into meaningful detection

Why This Matters

- We already have strong foundations:
 - STIX for sharing intelligence
 - MITRE ATT&CK for adversary techniques
 - D3FEND for defensive techniques
- But in practice:
 - These describe threats...
 - They don't define how to detect and act on them operationally
- The gap:
 - No standard way to share:
 - Detection logic
 - Correlation strategies
 - Response workflows

We can share knowledge but not operational capability

Motivation for the Research

- Defenders need more than indicators or attack patterns
- They need:
 - Shareable detection logic
 - Built-in correlation
 - Specificity that drives actionable response

Something between IOCs and ATT&CK

Something operational

ATT&CK shows what type of data to look for

Reconnaissance	Resource Development	Initial Access	Execution	Persistence
10 techniques	7 techniques	9 techniques	12 techniques	19 techniques
Active Scanning (2)	Acquire Infrastructure (6)	Drive-by Compromise	Command and Scripting Interpreter (8)	Account Manipulation (4)
Gather Victim Host Information (4)	Compromise Accounts (2)	Exploit Public-Facing Application	Container Administration Command	BITS Jobs
Gather Victim Identity Information (3)	Compromise Infrastructure (6)	External Remote Services	Deploy Container	Boot or Logon Autostart Execution (15)
Gather Victim Network Information (6)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Boot or Logon Initialization Scripts (5)
Gather Victim Org Information (4)	Establish Accounts (2)	Phishing (3)	Inter-Process Communication (2)	Browser Extensions
Phishing for Information (3)	Obtain Capabilities (6)	Replication	Native API	Compromise Client Software Binary
Search Closed Sources (2)	Stage Capabilities (15)	Removable Media	Scheduled Task/Job (6)	Create Account (3)
Search Open Technical Databases (3)		Supply Chain Compromise (3)	Shared Modules	Create or Modify System Process (4)
Search Open Websites/Domains (2)		Trusted Relationship	Software Deployment Tools	

Application Log

Events collected by third-party services such as mail servers, web applications, or other appliances (not by the native OS or platform)^[1]

Definition

Ascertaining sender reputation based on information associated with a message (e.g. email/instant messaging).

How it works

Sender trust rating can be considered an indicator of the level of security risk and/or a trust level associated with a sender. The features considered in determining sender trust rating include:

- Length of time sender has sent emails to the enterprise
- Number of recipients in the enterprise the sender interacts with
- Sender vs. enterprise originated message ratio
- Sender messages opened vs. not-opened ratio
- Number of emails received from this sender
- Number of emails replied to this sender
- Number of emails from this sender not opened
- Number of emails from this sender not opened that contain an attachment
- Number of emails from this sender not opened that contain a URL
- Number of emails sent to this sender
- Number of email replies received from this sender.

Higher values for the number of recipients the sender has interacted with or the number of emails received from the sender, for example, results in a higher trust rating. The trust rating can categorize the sender as unrated, neutral, trusted, suspicious, or malicious.

Considerations

Legitimate emails from a sender may receive a lower trust rating over time if the sender's domain gets spoofed and is used to send unauthorized emails.

Digital Artifact Relationships:

This countermeasure technique is related to specific digital artifacts. Click the artifact node for more information.



ID: D3-SRA (Sender Reputation Analysis)

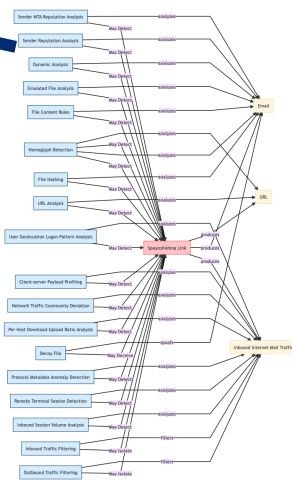
Spearphishing Link

MITRE ATT&CK LINK

Inferred Relationships

Note: The inference is not fully finalized in this release. This page is experimental and will change significantly in future releases.

Show the D3FEND knowledge graph by clicking on the nodes below.



D3FEND provides context of what one could detect

What is an Indicator of Behavior (IOB)?

- Structured Threat Information eXchange (STIX)
 - JSON standard to represent Cyber Threat Intelligence
 - Provides a shareable knowledge graph
 - <https://oasis-open.github.io/cti-documentation/>
- Indicator of Behavior (IOB) STIX bundles provide repeatable sets of observed adversary behaviors to help defender tools & capabilities
 - Intelligence context provided in machine-readable graph representation
 - Relationships to relevant ATT&CK attack pattern objects
 - Relationships to detection analytics
 - Includes correlation workflows to address false positives
 - Includes response Courses of Action (COAs) and cybersecurity operations playbooks in standardized formats

Each procedure can be easily detected but has high potential for false positives

Machine
Opens
Suspicious
Email

PowerShell
Run for
First Time

Machine
Registry
Modified

Machine
Accesses
Network
Share

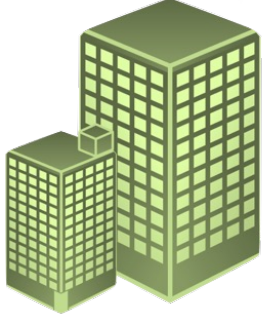
The sequence of procedures is most likely malicious

HudsonAlpha – Not Your Typical Network

- **Cutting-Edge Genomics Research:**
 - Leads in advancing genomic science
 - Medical and Agricultural focus
- **Innovation Hub:**
 - Hosting over 40 biotech companies
 - Provides network access and network security for these startups
- **Educational Outreach:**
 - Partnered with the University of Alabama at Birmingham
 - Offers programs for students, educators, and the public to promote genomic literacy and inspire future scientists.



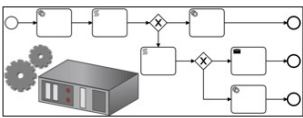
Pilot Design



1

HudsonAlpha provided information on Security operations:

- Log Sources
- SIEM
- SOAR
- TIP
- Firewalls, Proxies, EDR, etc.



APL provided HudsonAlpha with

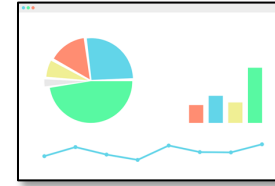
4

- IOB Bundles in STIX format
- Translation/Processing Code
- SIEM analytics/alerts in desired format
- Metrics
- Correlation/Response playbooks in preferred format
- Integration/Consultation for deployment in operational environment (if desired)

5

HudsonAlpha provided

- Feedback on usefulness of analytics
- Desired features for IOB to improve usability/performance
- Metric performance



2

APL recreated HudsonAlpha environment in Integration Environment

- Deploy same version of technology as HudsonAlpha
- Representative network and endpoint traffic
- Log Collection
- Creation of additional open source capabilities (if needed)

3

APL Translated IOB bundles for HudsonAlpha environment with their input

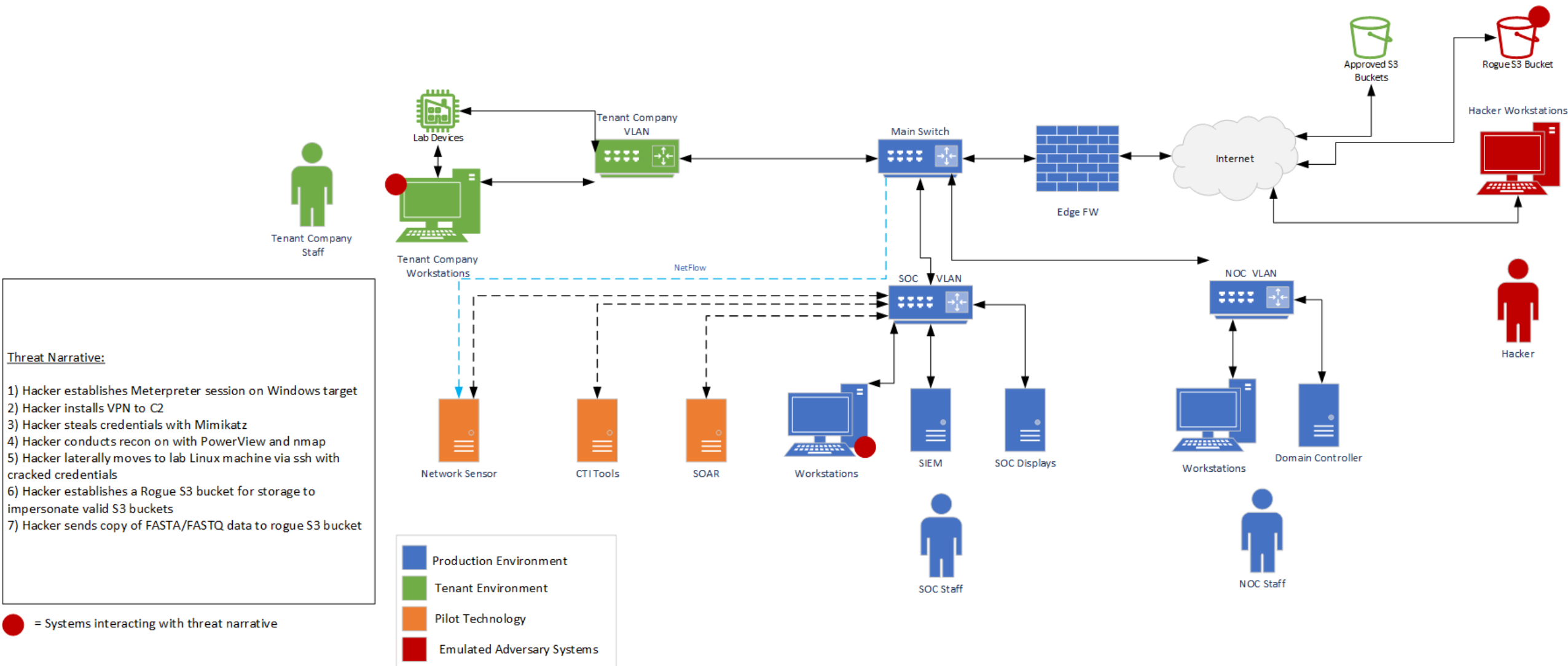
- Translation of analytics to SIEM format
- Integration of analytics on test technology stack
- Test of SIEM alerts/alerts
- Development of SOAR correlation workflows / playbooks
- Metrics and data collection methodology



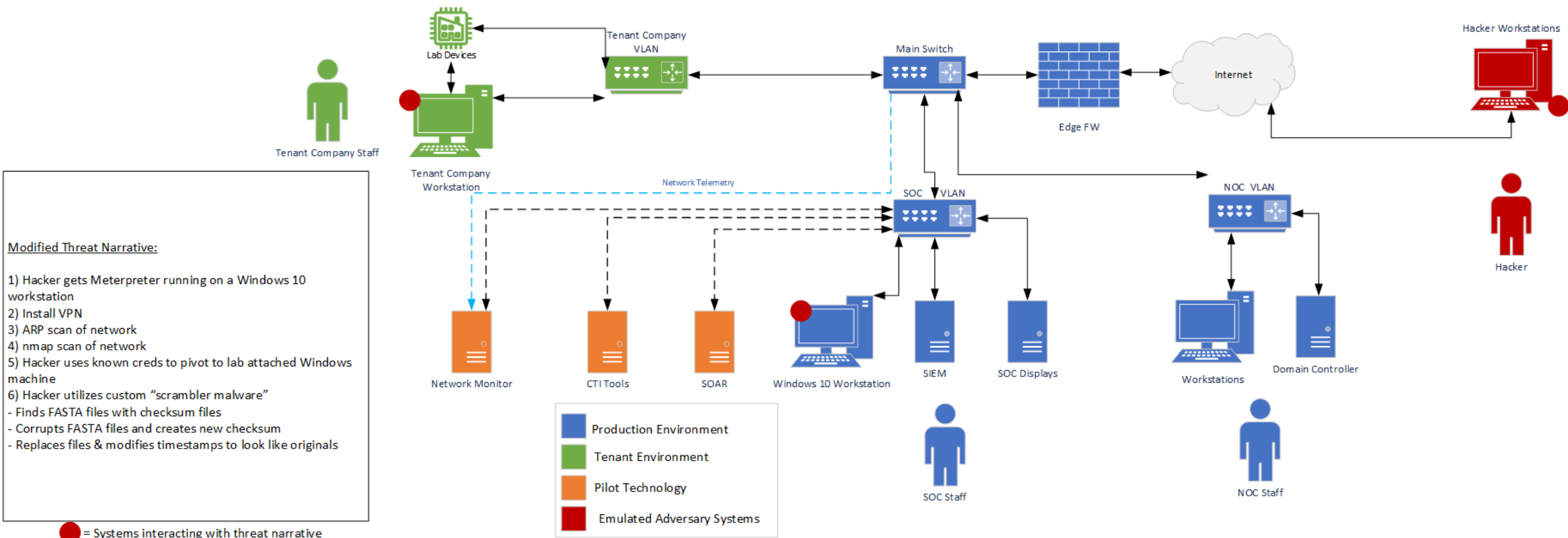
JOHNS HOPKINS
APPLIED PHYSICS LABORATORY



Pilot Use Case 1 – Data Theft

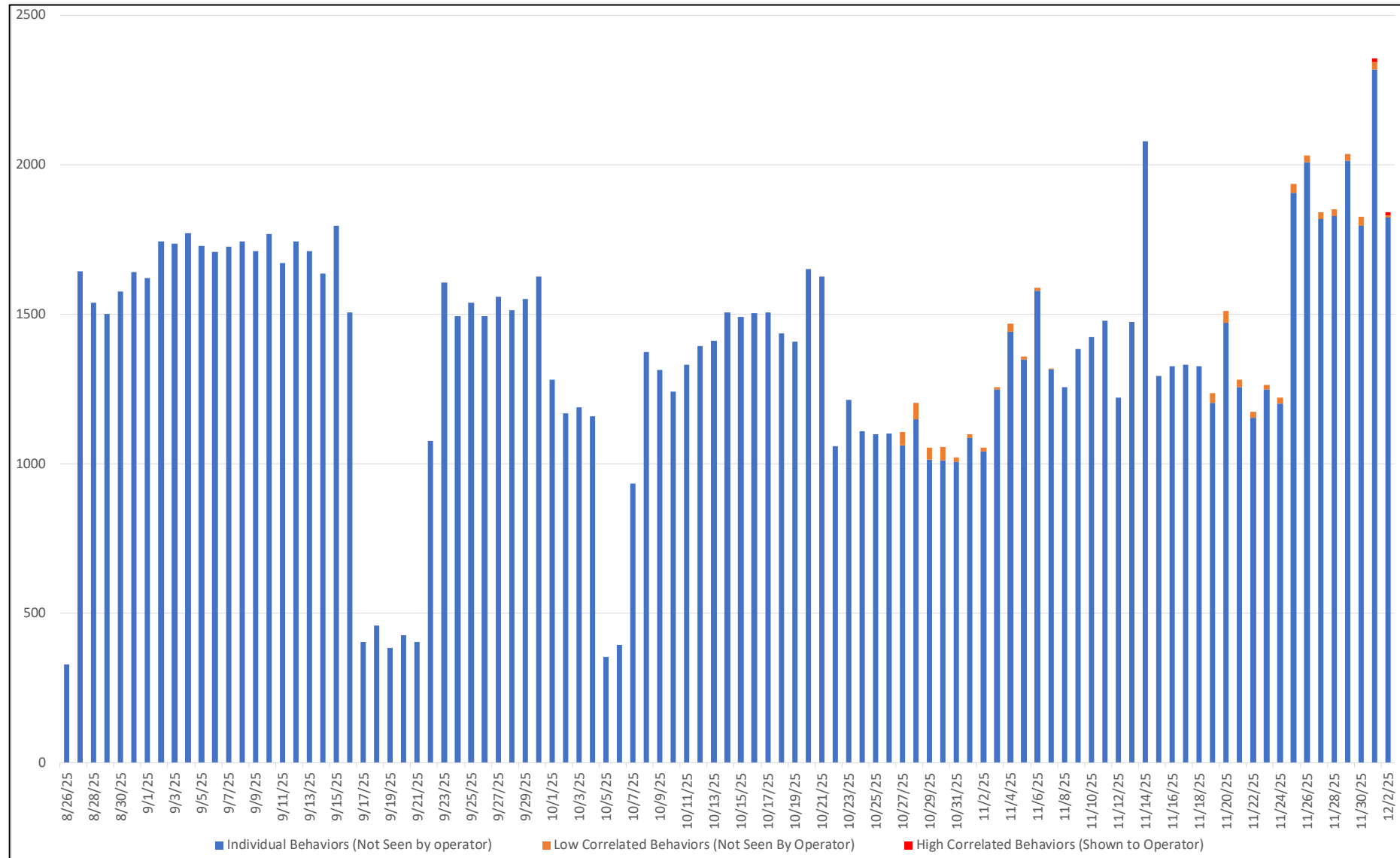


Pilot Use Case 2 – Data Integrity



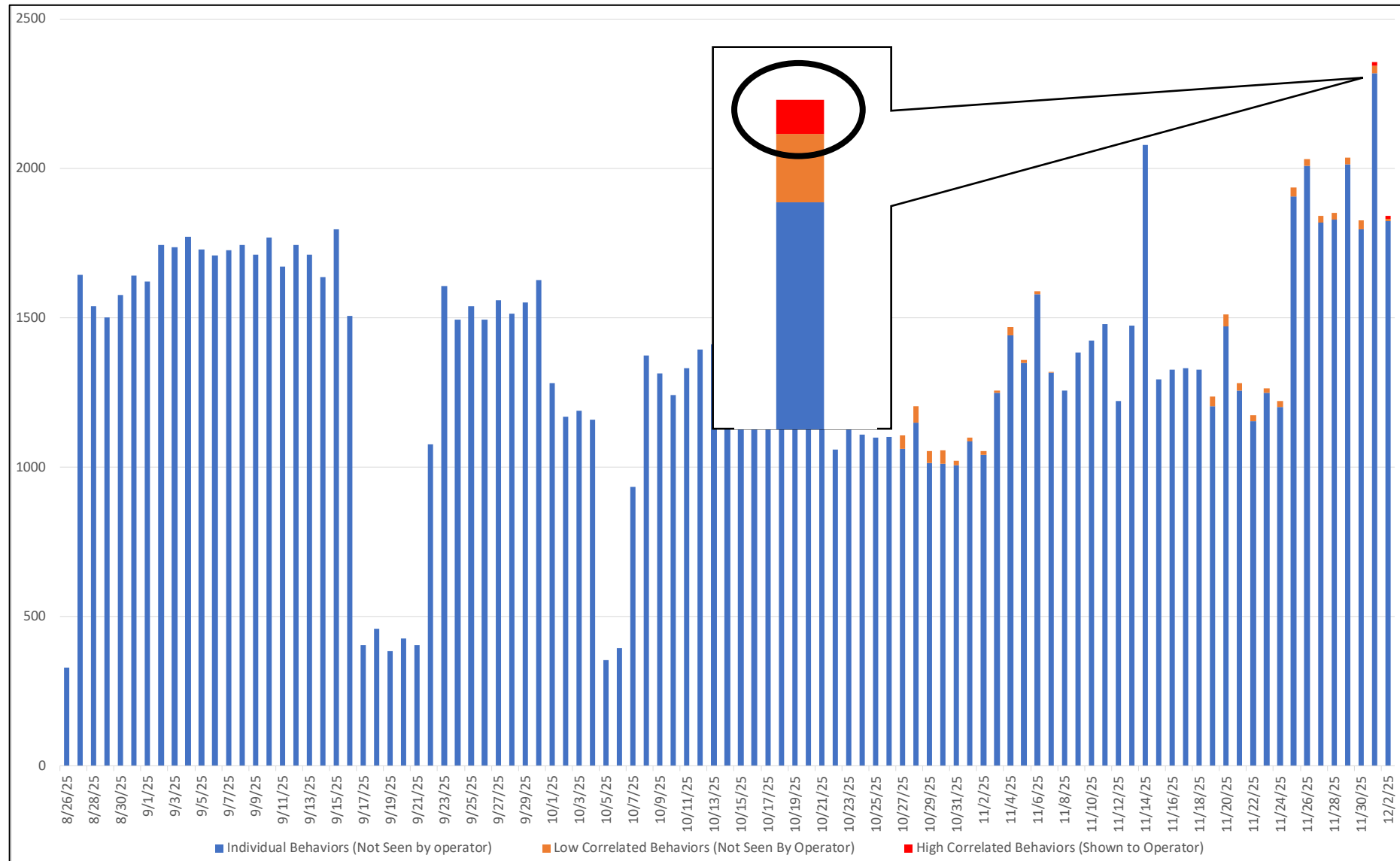
Individual Signals Are Noise

- Individual behaviors can be detected thousands of times
- This is not shown to an operator but handled by pilot automation



Individual Signals Are Noise

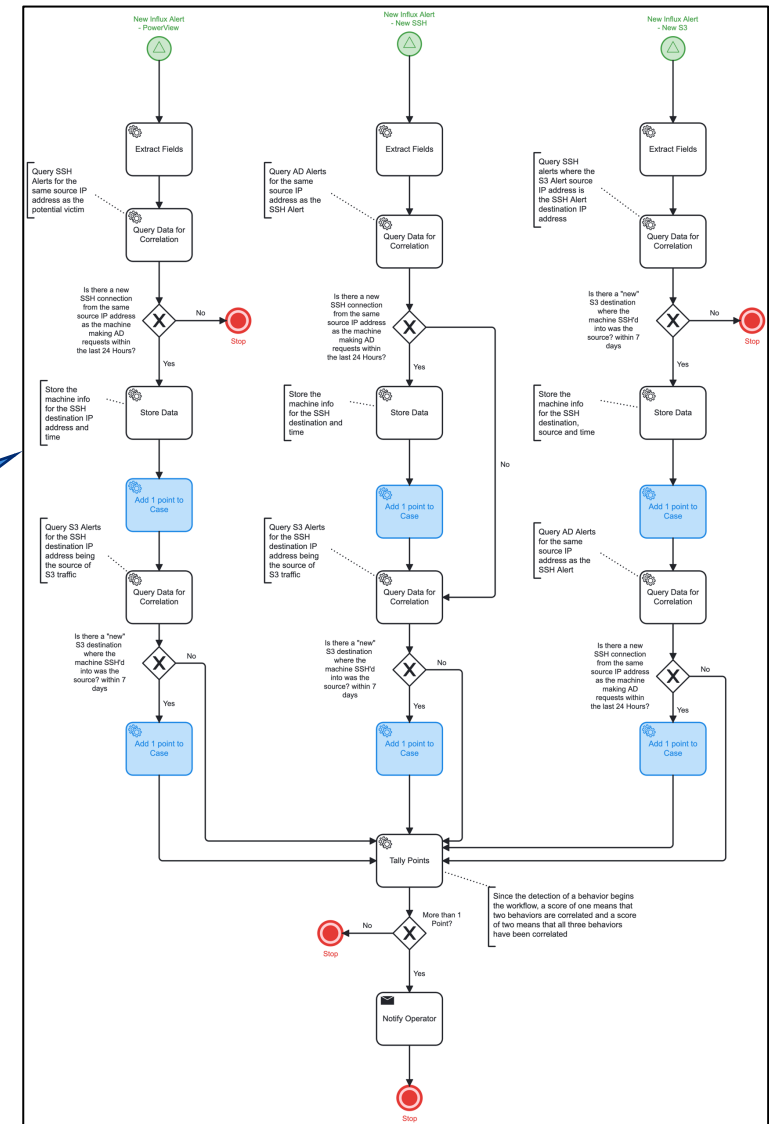
- Individual behaviors can be detected thousands of times
- This is not shown to an operator but handled by pilot automation
- IOB pilot only alerts an operator when a correlated set of behaviors have been detected



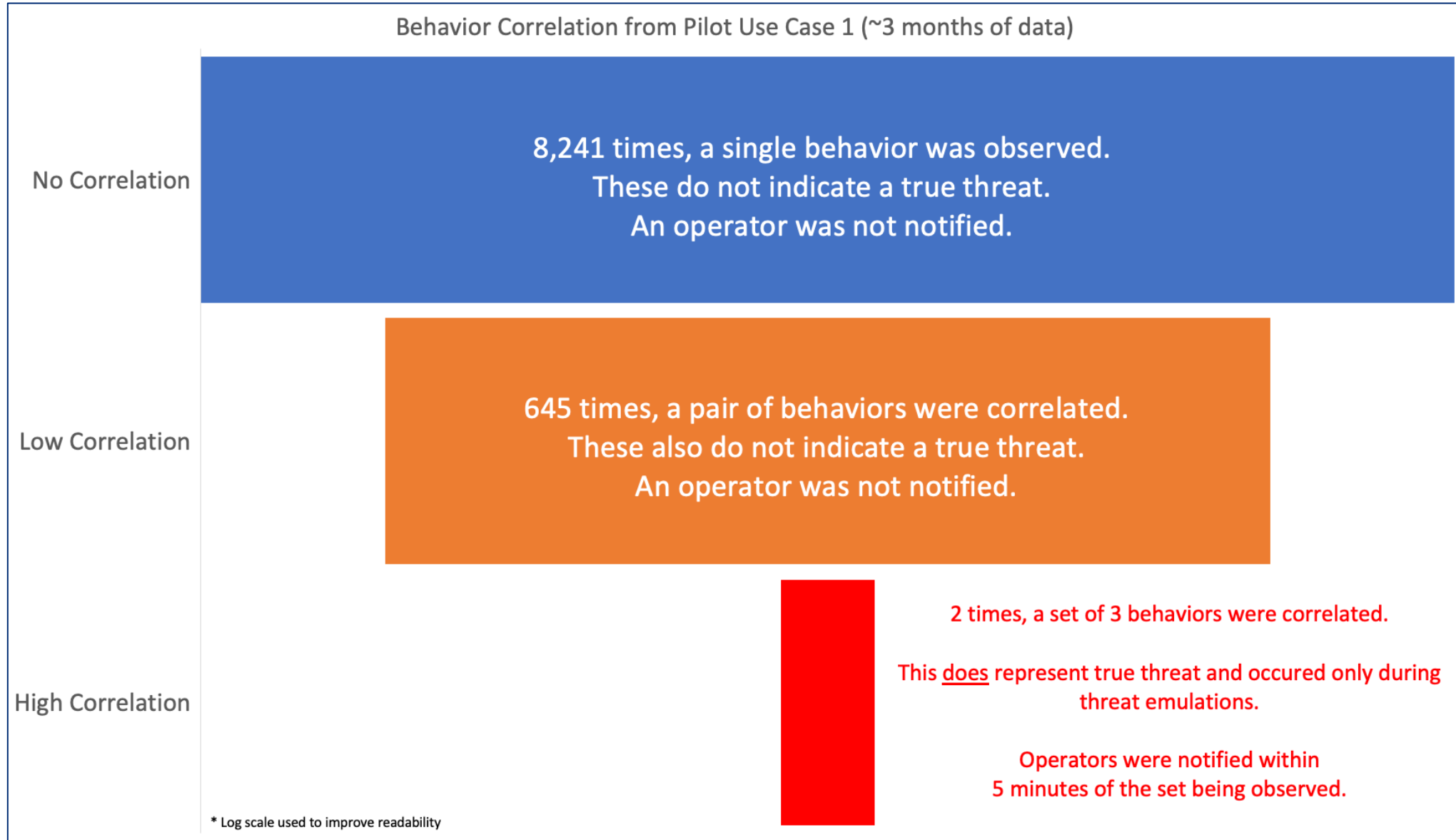
Behavior Correlation Changes Everything

- A key aspect to the data shared within the IOB structure is alert correlation logic
- These are shared within the IOB STIX JSON in vendor agnostic formats so they can be implemented on any number of technology stacks
- This allows operators to only be alerted when a malicious sequence of behaviors has been observed

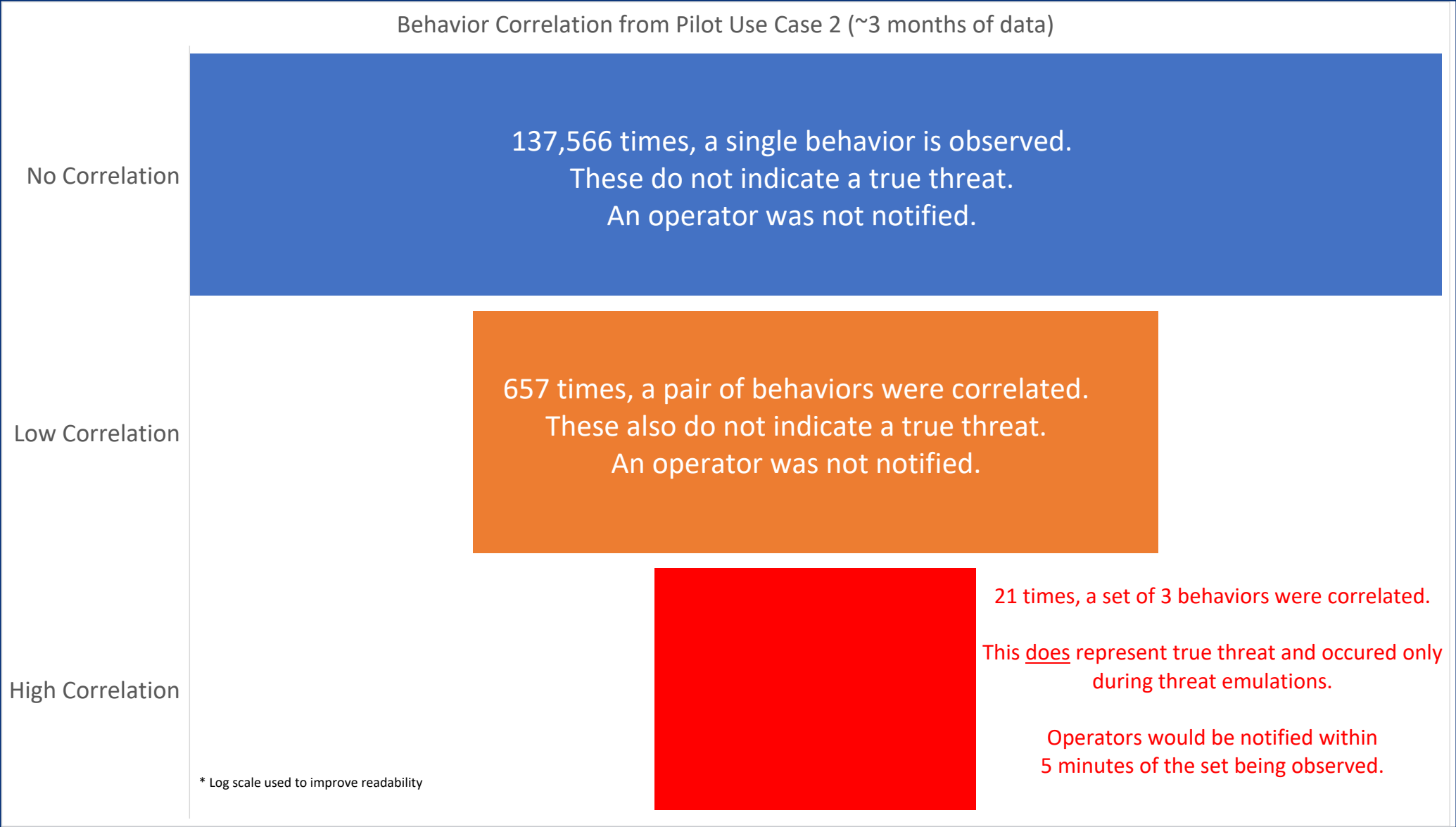
- Did a computer potentially map the network?
- If so, did that same computer make new remote sessions?
- If so, did that remote session start sending data to an S3 bucket we've never seen before?
- When we see all 3, alert an operator that there may be a problem



Results – Use Case 1



Results – Use Case 2



What We Learned

- Behavior-based detection works in real operations, not just in theory
- Correlation is the key to reducing noise and increasing confidence
- Thousands of benign signals can be safely ignored
- High-fidelity alerts emerge only from coordinated behavior sequences
- Open, machine-readable formats make this portable across tools and environments

The advantage isn't more data, it's better context

Conclusion & Resources

- Indicators of Behavior enable earlier, more precise detection of adversary activity
- Proven in a live biotechnology SOC with:
 - Rapid detection (~5 minutes)
 - All detections associated with valid emulated threat activity
 - Minimal operational disruption
- Explore more with IOB
 - IOB Project and Reference Implementations: <https://github.com/opencybersecurityalliance/oca-iob>
 - Direct Link to Pilot Report and IOB objects:
https://github.com/opencybersecurityalliance/oca-iob/tree/main/apl_reference_implementation_bundle/iob_pilot





JOHNS HOPKINS
APPLIED PHYSICS LABORATORY